
Tutorial 5 Solution

Malware Threats

Computer Security BCS2420

Part A

1. **Answer:** A. It is theoretically proven that a perfect malware detector cannot exist in all cases.
Explanation: The theoretical proof resembles the undecidability problem in computability theory (akin to the Halting Problem).
2. **Answer:** B. Worms spread autonomously through network vulnerabilities, whereas viruses typically rely on users executing infected files.
Explanation: This is the hallmark difference: worms do not need user intervention to propagate.
3. **Answer:** C. A rootkit
Explanation: Rootkits hide themselves by intercepting system calls, returning filtered results that exclude their presence.
4. **Answer:** C. Malware that encrypts user data and demands payment to restore access
Explanation: This is the essence of ransomware: holding the data hostage.
5. **Answer:** A. The malware's encrypted body changes with each infection to evade signature detection.
Explanation: Polymorphic malware modifies its decryptor and/or encryption layer frequently.
6. **Answer:** B. Exploiting browser or plugin vulnerabilities without user awareness
Explanation: Drive-by downloads rely on silent exploits in a user's web session.

7. **Answer:** B. To stealthily manipulate API results, hiding the rootkit's presence or actions
Explanation: Hooking allows the rootkit to alter returned data from OS functions.
8. **Answer:** C. A single centralized server is the only way to manage botnets.
Explanation: This is *false*. Botnets can have peer-to-peer or multi-layer command structures.
9. **Answer:** C. Capture user keystrokes to harvest passwords or other sensitive data
Explanation: Keyloggers specifically record keystrokes.
10. **Answer:** B. Manipulating the kernel's internal data structures (DKOM) to hide processes or network connections
Explanation: Kernel-mode rootkits often use DKOM to avoid detection by standard system utilities.
-

Part B

1. Malware Installation Pathways

- **Email Attachments:** Example - The "ILOVEYOU" worm. Users open a suspicious attachment, inadvertently executing malware.
- **Drive-by Downloads:** Malicious website injects exploits into a user's browser (e.g., exploit kits hosted on compromised sites).
- **Trojanized Software:** A legitimate installer repackaged with hidden malware (e.g., infected game mods or "free software" found on shady websites).

2. Virus vs. Worm Differences

- **Infection Mechanism:** Viruses infect files or boot sectors; worms propagate via network scanning and exploiting vulnerabilities.
- **Propagation:** Viruses rely on user actions (e.g., running an infected file); worms self-propagate automatically.
- **User Involvement:** Viruses typically need user execution; worms do not.
- **Implications:** Defenses must consider limiting user access (to mitigate viruses) and network-based

patching/intrusion detection (for worms).

3. Rootkit Detection Challenges

- **Stealth Techniques:**

1. **System Call Hooking:** Intercepts OS calls to hide malicious processes and files.
2. **Direct Kernel Object Modification (DKOM):** Alters kernel data structures to falsify system views.

- **Why Hard to Remove:** Rootkits operate at low levels (kernel space). Traditional antivirus at user level may not see the tampered system calls, and removing them might require a complete OS reinstall.

4. Polymorphic vs. Metamorphic Malware

- **Polymorphic:** Maintains the same underlying malicious code but encrypts the body with a variable decryptor. Primary difference is the changed "wrapper," but core logic remains the same.
- **Metamorphic:** Rewrites its own code (instructions, structure) for each infection, potentially no static signature.
- **Effect on Signature Detection:** Both hamper static signatures. Polymorphic changes the decryptor portion; metamorphic can significantly alter code structure.

5. Ransomware Workflows

- **Steps:**

1. Initial compromise (phishing or exploit).
2. Malware execution and stealthily scanning for files.
3. Encryption of key files with a unique symmetric key.
4. Encryption of the symmetric key with attacker's public key.
5. Ransom note demanding payment to decrypt.

- **Offline Backup Attacks:** Modern strains often seek and encrypt or corrupt backups to ensure no easy recovery path.

6. Botnet Control Structures

- **Centralized:** Strength – easy for botmaster to issue commands; weakness – single point of failure if the C2 server is shut down.
- **Peer-to-Peer:** Strength – more resilient, no single takedown point; weakness – more complex to design,

possibly slower command propagation.

7. Drive-by Download Mechanisms

- **Browser Exploit:** Attackers embed JavaScript or malicious payloads that exploit a plugin or browser vulnerability.
- **Redirection/Obfuscation:** The user might be sent through multiple redirect links or encoded scripts to hide the final payload URL. Harder for defenders to block or track.

8. Kernel-Mode vs. User-Mode Rootkits

- **Kernel-Mode:** Full privileges, can manipulate system calls at the OS core. Potentially more powerful and stealthy.
- **User-Mode:** Intercepts calls at the application level (e.g., hooking IAT). Easier to develop but less control than kernel-level.
- Kernel-mode rootkits are more dangerous because they operate where security software also runs, making detection and removal difficult.

9. Trojan Horses and Backdoors

- **Embedding:** Attackers modify legitimate software, injecting malicious code that opens a hidden port or user account.
- **Value:** Provides persistent, secret access for exfiltration or advanced attacks. Maintains stealth if disguised as a legitimate process.

10. Vulnerability Exploits and Malware

- **Example Vulnerabilities:**
 1. **Buffer Overflow:** Allows arbitrary code execution at the privilege level of the vulnerable program.
 2. **SQL Injection:** Attackers can insert commands to manipulate backend databases or retrieve sensitive info.
 - **Importance of Patching:** Quick patching prevents malware from exploiting known flaws, limiting widespread infection.
-

Part C

1. Worm Spread Rate

- **Rate:** 10^6 probes/hour.
- **Vulnerable fraction:** $0.01\% = 0.0001$.
- **New infections/hour** = $10^6 \times 0.0001 = 100$.
- If the infected population doubles every hour, after 5 hours:
 - Initial = 100 (hour 1).
 - Hour 2 = 200, Hour 3 = 400, Hour 4 = 800, Hour 5 = 1600.
 - Or if we strictly track from "start," we might say $100 \rightarrow 200 \rightarrow 400 \rightarrow 800 \rightarrow 1600$, so about 1,600 infected after 5 cycles.

2. Ransomware File-Encryption Scale

- RSA encryption step: 20ms per encryption of the AES key.
- **5000 systems** $\rightarrow 5000 \times 20\text{ms} = 100,000\text{ms} = 100$ seconds.
- ≈ 1.67 minutes to encrypt all those AES keys across 5000 victims.

3. Botnet Attack Throughput

- **50,000 zombies**, each can send **10,000** spam emails/hour.
- **Per day:** 24 hours $\rightarrow$
 - Hourly total = $50,000 \times 10,000 = 5 \times 10^8$ emails/hour.
 - Daily total = $5 \times 10^8 \times 24 = 1.2 \times 10^{10}$ emails 12 billion emails/day.

4. Polymorphic Malware Signature Coverage

- Malware generates 100 new decryptor shapes per day.
- Antivirus can issue 1 signature update daily.
- In 7 days, malware = $(100 \times 7 = 700)$ forms. Antivirus = 7 new signatures.
- Even if each signature covers 1 variant, $(700 - 7 = 693)$ forms remain *uncovered*. The gap grows, outpacing daily signature updates.